

Netisens Cybersecurity April Cohort Presentation

OSINT Tools &
Vulnerability Assessments
Presentation

Prepared by
Adeleke Theophilus
Ndifreke Sylvester Romanus

Table of Contents

1. Executive Summary
2. Objectives of the Assessment
3. Scope
4. OSINT Tools Overview
5. Why Information is Publicly Available
6. Data Categories Reviewed
7. Dangers of Exposed Information
8. Exposure Risks & Attack Scenarios
9. OSINT Findings Summary
10. Mitigation Strategies
11. Best Practices for Reducing OSINT Footprint
12. Conclusion

**DISCLAIMER JUST FOR
EDUCATIONAL PURPOSES**

1. Executive Summary

As part of a collaborative cybersecurity research initiative, our team conducted an external reconnaissance and exposure assessment on two publicly accessible domains to evaluate open-source intelligence risks and strengthen defensive awareness. The objective was to identify publicly available information that could be leveraged by threat actors during the early stages of an attack, without performing unauthorised intrusion or exploitation.

Using SpiderFoot and theHarvester for passive OSINT collection, though we are restricted from going further, the team gathered intelligence, including domain records, subdomains, certificate transparency entries, employee email patterns, service banners, and publicly referenced credentials. These findings were analysed to understand how attackers could potentially map the organisation's digital footprint, target exposed services, execute social-engineering campaigns, or prepare exploitation strategies against outdated or misconfigured systems.

Throughout the assessment, strict rules of engagement were maintained, with the primary focus on intelligence gathering rather than active exploitation. The collected data was reviewed, validated, and categorised by security relevance, demonstrating how even publicly accessible information can introduce material risk when left unmanaged.

This project enhanced the team's understanding of adversarial reconnaissance workflows. It emphasised the importance of proactive attack-surface monitoring, strong authentication controls, continuous oversight of certificates and subdomains, and timely patching of exposed services. Ultimately, the assessment reinforced the need for ongoing OSINT-based visibility to reduce exposure and strengthen organisational cybersecurity resilience.

2. Objective

1. Collect OSINT data on two domains.
2. Map publicly exposed services.
3. Identify exploitable public information.
4. Recommend security improvements.
5. Present findings professionally.

3. Scope

The assessment focused on two publicly accessible domains, using passive OSINT collection techniques such as SpiderFoot and theHarvester. Only limited and non-intrusive service mapping was performed, with no exploitation or intrusive testing carried out at any stage. The engagement was strictly for intelligence gathering and awareness, followed by reporting and defensive recommendations to help strengthen the security posture.

4. OSINT Tools Overview

1. SpiderFoot (v4.0)

Automated OSINT tool for gathering domain, subdomain, DNS, and public exposure data.

New Scan

Scan Name

The name of this scan.

Scan Target

The target of your scan.

Your scan target may be one of the following. SpiderFoot will automatically detect the target type based on the format of your input:

Domain Name: e.g. example.com

IPv4 Address: e.g. 1.2.3.4

IPv6 Address: e.g. 2606:4700:4700::1111

Hostname/Sub-domain: e.g. abc.example.com

Subnet: e.g. 1.2.3.0/24

Bitcoin Address: e.g. 1HesYJSP1QqcyPEjnQ9vzBL1wujuNGe7R

E-mail address: e.g. bob@example.com

Phone Number: e.g. +12345678901 (E.164 format)

Human Name: e.g. "John Smith" (must be in quotes)

Username: e.g. "jsmith2000" (must be in quotes)

Network ASN: e.g. 1234

By Use Case

By Required Data

By Module

☒ All

Get anything and everything about the target.
All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

☐ Footprint

Understand what information this target exposes to the Internet.
Gain an understanding about the target's network perimeter, associated identities and other information that is obtained through a lot of web crawling and search engine use.

☐ Investigate

Best for when you suspect the target to be malicious but need more information.
Some basic footprinting will be performed in addition to querying of blacklists and other sources that may have information about your target's maliciousness.

☐ Passive

When you don't want the target to even suspect they are being investigated.
As much information will be gathered without touching the target or their affiliates, therefore only modules that do not touch the target will be enabled.

Run Scan Now

2. theHarvester (v4.3.0)

OSINT tool for collecting emails, subdomains, and hostnames from public sources.

```
(kali@kali)-[~]
└─$ theHarvester
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*  _ _ _ _ _  ^  ^  _ _ _ _ _  *
*  | | | | |  /  /  \  \  \  \  *
*  | | | | |  v  v  /  /  /  /  *
*  | | | | |  v  v  /  /  /  /  *
*  _ _ _ _ _  *
* theHarvester 4.8.2 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
* *
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s]
                  [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t]
                  [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME]
                  [-w WORDLIST] [-a] [-q] [-b SOURCE]
theHarvester: error: the following arguments are required: -d/--domain
```

5. Why Information is Publicly Available

Taking [_____](#).com and [_____](#) as a case study using **SpiderFoot** and **theHarvester**.

Information is publicly available because organisations and individuals routinely publish data online for communication, transparency, marketing, and operational purposes. This includes details like domain names, IP addresses, server information, and emails, which are often indexed by search engines, archived in public databases, or stored on social media and other online platforms. While this data is not confidential, it can reveal digital footprints that attackers could exploit if left unmonitored.

project1 ABORT-REQUESTED

Summary

Correlations

Browse

Graph

Scan Settings

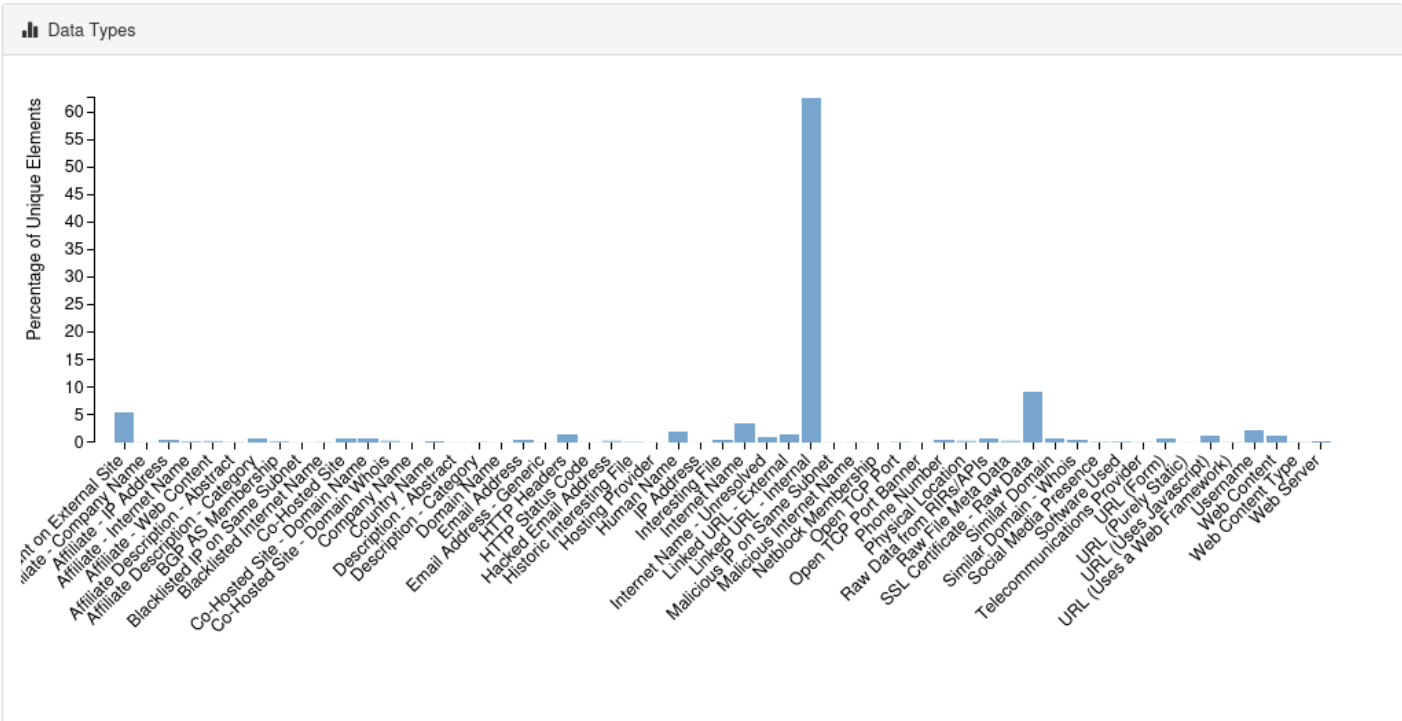
Log

Scan Status

Total4471Unique3442StatusABORT-REQUESTEDErrors0

Correlations

High0Medium0Low0Info0



scan summary

Test **ABORT-REQUESTED**

ABORT-REQUESTED

Summary

Correlations

 Browse

- * Graph

⚙️ Scan Settings

 Log Scan Status

Total

1978

Unique

Status

ABORT-REQUESTED

0

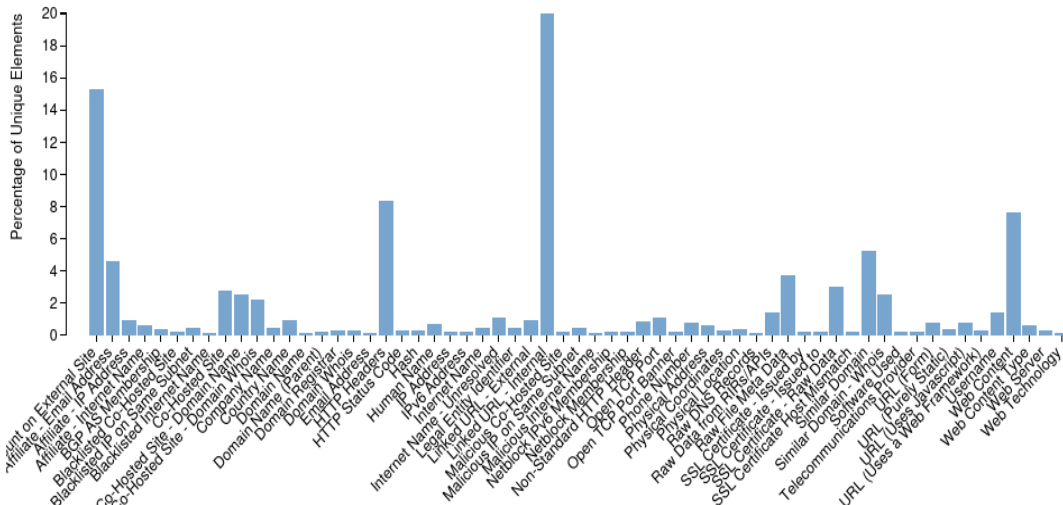
Correlations

High	0
------	---

Low	0
-----	---

Info 0

■ Data Types



scan summary

OSINT (Open-Source Intelligence) tools allow security professionals to collect and analyse this publicly accessible information. They do not hack or break into systems; they gather what is already exposed online, helping organisations identify potential vulnerabilities and strengthen defences.

Tool Comparison: SpiderFoot vs theHarvester

To illustrate this, we used two popular OSINT tools:

- **SpiderFoot:** Provides a deep and automated scan across multiple data sources, revealing emails, subdomains, IP addresses, technologies, and relationships. It can reveal information that is scattered across various sources, making it easier to visualise potential attack surfaces.
- **theHarvester:** Focuses on specific data types like emails, hosts, or subdomains from limited sources. In our scan, theHarvester returned fewer results, highlighting that not all OSINT tools collect the same depth of publicly available information.

Observation: The difference in results demonstrates how some information might seem “hidden” but is actually publicly accessible. SpiderFoot could aggregate it, while theHarvester could not.

6. Data Categories Reviewed

As part of this OSINT-based security assessment, multiple categories of publicly accessible information related to the target organisation were reviewed. The objective was to identify exposed data points that attackers could leverage for reconnaissance, initial access, or social engineering. Information was collected using two OSINT tools, **SpiderFoot and theHarvester** and analysed to understand the security implications and degree of exposure.

1. Open TCP (MySQL 3306) - _____ using spiderfoot

Test

ABORT-REQUESTED

Summary	Correlations	Browse	Graph	Scan Settings	Log						Search...	
Browse / Open TCP Port												
☐	Data Element		Source Data Element		Source Module		Identified					
☐	119.2	usercontent.com:443	119.2	gleusercontent.com	sfp_sslcert		2025-11-02 18:34:52					
☐	34.12		34.1		sfp_portscan_tcp		2025-11-02 18:03:17					
☐	34.12		34.1		sfp_sslcert		2025-11-02 18:32:46					
☐	34.12		34.1		sfp_portscan_tcp		2025-11-02 18:03:02					
☐	82.25		82.25		sfp_portscan_tcp		2025-11-02 16:57:22					
☐	82.25		82.25		sfp_portscan_tcp		2025-11-02 16:56:50					
☐	82.25		82.25		sfp_sslcert		2025-11-02 16:47:01					
☐	82.25		82.25		sfp_portscan_tcp		2025-11-02 16:57:22					
☐	82.25		82.25		sfp_portscan_tcp		2025-11-02 16:57:06					

Also, using nmap to check the version of the open port

```
(kali@kali)-[~]
$ nmap -sV 8.11.1.1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 12:03 EST
Nmap scan report for 8.11.1.1
Host is up (0.015s latency).
Not shown: 984 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp            ProFTPD or KnFTPD
80/tcp    open  http           LiteSpeed httpd
443/tcp   open  ssl/http       LiteSpeed httpd
587/tcp   open  submission?
2103/tcp  closed zephyr-clt
2111/tcp  closed kx
2119/tcp  closed gsigatekeeper
2170/tcp  closed eyetv
2179/tcp  closed vmrdp
2200/tcp  closed ici
2222/tcp  closed EtherNetIP-1
2301/tcp  closed compaqdiag
2399/tcp  closed fmpro-fdal
3306/tcp  open  mysql          MariaDB 11.8.3
60443/tcp closed unknown
Service Info: OS: Unix
```

Although several TCP ports, such as port 80 (HTTP) and port 443 (HTTPS), are open, our primary focus in this assessment is the **MySQL database service**. The database version identified is **MariaDB 11.8.3**, which is publicly exposed. HTTP and HTTPS are open because they are required for web access. In this environment, the web server version detected for both HTTP and HTTPS is **LiteSpeed**, while in the case, the web server in use is **Nginx**. However, in both cases, ports 80 and 443 remain publicly accessible as expected.

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali ~  
$ nmap -sV [redacted]  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 12:07 EST  
Nmap scan report for [redacted]  
Host is up (0.030s latency).  
Not shown: 996 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; pr  
otocol 2.0)  
80/tcp    open  http      nginx  
443/tcp   open  ssl/https nginx  
587/tcp   open  submission?  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://n  
map.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 124.94 seconds
```

Using theHarvester to scan _____, we found that it did not give us in-depth unlike the spiderfoot

```
kali@kali: ~  
$ theHarvester -d [redacted] -b duckduckgo -l 100 -f results.html  
Read proxies.yaml from /etc/theHarvester/proxies.yaml  
*****  
* theHarvester 4.8.2 *  
* Coded by Christian Martorella *  
* Edge-Security Research *  
* cmartorella@edge-security.com *  
*****  
[*] Target: [redacted]  
[*] Searching Duckduckgo.  
[*] No IPs found.  
[*] No emails found.  
[*] No people found.  
[*] No hosts found.  
  
[*] Reporting started.  
[*] XML File saved.  
[*] JSON File saved.
```

But when run on _____ we are unable to find an open port, but some information is found.

The PHP version in use is PHP 8.2.28, which is already an older release and no longer receiving security updates or patch support. Running an unsupported PHP version increases exposure to known vulnerabilities that attackers can exploit, since no new security fixes will be released for it. Also, Technology is not publicly available

3. Malicious IP Address on the same subnet

Test ABORT-REQUESTED

Summary

Correlations

Browse

Graph

Scan Settings

Log

Search...

Browse / Malicious IP on Same Subnet

☐	Data Element	Source Data Element	Source Module	Identified
☐	c h italk_7d.ipset	34	sfp_cleantalk	2025-11-02 18:01:37
☐	v h /14	34	sfp_voipbl	2025-11-02 18:03:28
☐	b h it	34	sfp_blocklistde	2025-11-02 18:06:57
☐	c h :xt	34	sfp_cinsscore	2025-11-02 18:03:28
☐	g h 14	34	sfp_greensnow	2025-11-02 18:03:20

scan

project1 ABORT-REQUESTED

Summary

Correlations

Browse

Graph

Scan Settings

Log

Search...

Browse / Malicious IP on Same Subnet

☐	Data Element	Source Data Element	Source Module	Identified
☐	Vo1 htt /15	99	sfp_voipbl	2025-11-02 18:41:56

scan

During the reconnaissance phase, it was discovered that [redacted] and [redacted] share the same subnet with a malicious IP address. This is a security concern because having a hostile system in close network proximity increases the likelihood of targeted scanning, probing, and attempted exploitation against nearby hosts. Such adjacency can also facilitate lateral movement if vulnerabilities exist.

4. Exposed Phone Number (human attack vector)

☐	+23 687	<!DOCTYPE html> <!--[if IE 9]> <html class="no-js oldie ie9 ie" dir="ltr" lang="en-US" prefix="og: https://ogp.me/ns#" > <![endif]--> <!--[if (gt IE 9)]!(IE)]><!--> <html class="no-js" dir="ltr" lang="en-US" prefix="og: https://ogp.me/ns#" > <![endif]--> <head> <meta charset="UTF-8" > <meta http-equiv="X-UA-Compatible" content="IE=edge"> <!-- devices setting --> <meta name="viewport" content="initial-scale=1,user-scalable=no,width=device-width">	sfp_p hone	2025-11-0 2 17:03:3 3
--------------------------	------------	---	---------------	-----------------------------

phone number exposed

project1 ABORT-REQUESTED

Summary

Correlations

Browse

Graph

Scan Settings

Log

Search...

Browse / Phone Number

☐	Data Element	Source Data Element	Source Module	Identified
☐	+ 6	<!doctype html> <html lang="en-US"> <head> <!-- Basic --> <meta charset="UTF-8" /> <meta http-equiv="X-UA-Compatible" content="IE=edge"> <meta name="viewport" content="width=device-width, initial-scale=1.0"> <!-- fonts --> <link href="https://fonts.googleapis.com/css2?family=Inter:wght@100..900&display=swap" rel="stylesheet">	sfp_p hone	2025-11-0 2 20:14:2 5

phone number exposed

The assessment also identified publicly exposed phone numbers associated with the domain. While this may appear harmless at first, exposed contact information can be leveraged by attackers for **social engineering, phishing, and impersonation attacks**, especially against staff or administrators. This creates a direct pathway for threat actors to trick individuals into revealing sensitive credentials or granting unauthorised access. Protecting contact data and limiting public exposure reduces the risk of targeted human-based attacks that can compromise the entire system.

7. Danger of Exposed Information

- **Open MySQL (TCP 3306)**

Why vulnerable:

Publicly reachable databases expose authentication and protocol surfaces. Older MySQL releases often have published CVEs and proof-of-concept exploits that allow authentication bypass, remote code execution, or privilege escalation, meaning an attacker can exploit known flaws rather than craft a new exploit.

Potential losses:

Sensitive data exfiltration (PII, credentials, financials), credential reuse leading to app/domain compromise, and persistent footholds.

- **Web Technology(PHP)**

Why vulnerable:

Knowing the exact framework and versions lets attackers apply targeted CVE exploits. Plugins/themes are frequent weak links; unmaintained components often harbour critical vulnerabilities.

Potential losses:

Full application compromise, theft of user credentials and session tokens, data breaches, and reputational damage.

- **Malicious IP Address on Same Subnet**

Why vulnerable:

A hostile actor with network proximity can leverage trust assumptions and exploit unpatched internal services or weak segmentation. Older network stacks and unmanaged devices lack modern protections, making on-network attacks faster and more effective.

Potential losses:

Rapid lateral movement, interception of internal traffic, and escalation to critical infrastructure.

- **Exposed Phone Number (human attack vector)**

Why vulnerable (outdated makes it worse):

Public phone numbers enable vishing and SIM-swap attacks; reliance on SMS for account recovery or legacy verification processes amplifies this risk. Older operational procedures (manual resets, weak identity checks) are easily abused.

Potential losses:

Account takeover, social-engineering-driven credential resets, unauthorised access to critical accounts and services.

8. Exposure Risks & Attack Scenarios

Publicly exposed services and data discovered during reconnaissance create multiple, realistic attack paths:

- Database exposure (MariaDB 11.8.3 on 3306)
Risk: direct authentication or version-specific exploitation.
Attack scenario: Attacker enumerates MySQL, performs credential stuffing or uses a known CVE to dump the database, then reuses credentials for application-level or lateral access.
- Web servers (LiteSpeed / Nginx) & PHP 8.2.28 (unsupported)

Risk: outdated runtime and identifiable stack enable targeted CVE-based attacks.

Attack scenario: Attacker fingerprints the stack, finds a public exploit for an outdated PHP or plugin, executes RCE and deploys a webshell for persistent access.

- Open TCP services / extra ports

Risk: more potential entry points; outdated services have public exploits.

Attack scenario: Automated scan → banner grab → run existing exploit modules to gain initial foothold.

- Malicious IP on the same subnet.

Risk: On-network hostile presence increases the speed and success of active attacks.

Attack scenario: Hostile actor performs local reconnaissance and attempts MITM or lateral scanning against nearby hosts.

- Exposed phone number

Risk: social-engineering vector for account recovery or helpdesk manipulation.

Attack scenario: Vishing/SIM swap to perform password resets or bypass SMS-based MFA.

9. OSINT Findings Summary

During this assessment, open-source intelligence (OSINT) techniques were used to gather publicly accessible information related to the target environment. Using automated reconnaissance tools such as SpiderFoot and theHarvester, critical exposure points were identified across online infrastructure and associated digital fingerprints.

Analysis revealed multiple publicly visible services, technology stacks, network metadata, and contact information that can serve as valuable intelligence for threat actors. Key findings include visible web server technologies (LiteSpeed/Nginx), an exposed database service (MariaDB 11.8.3), running PHP version 8.2.28, which is already in the end-of-support stage, the presence of a malicious IP within the same subnet, and an exposed phone number tied to the organisation's digital footprint. These findings demonstrate the importance of continuous monitoring, strict service exposure control, and proactive hardening, as OSINT exposure significantly reduces an attacker's reconnaissance time and provides a foundation for targeted exploitation.

10. Mitigation Strategies

- Restrict and monitor open ports: Limit access to ports such as HTTP/HTTPS and MySQL to authorised users only, and enforce firewall rules to reduce external attack exposure.
- Upgrade outdated PHP version: The PHP version identified (8.2.28) is no longer receiving patches. Upgrade to a supported and secure PHP release to close vulnerabilities.
- Harden web server configuration: LiteSpeed and Nginx servers should be configured with strong security headers, disabled unnecessary modules, and frequent vulnerability scans.

- Monitor shared subnet activity: Since [redacted] and [redacted] share a subnet with known malicious IPs, continuous threat monitoring and IP reputation checking should be implemented.
- Mask or remove publicly exposed phone numbers: Replace direct contact numbers with web forms or VoIP redirection to reduce the risk of phishing, spam, and targeted attacks.
- Implement OSINT footprint monitoring: Regularly track online exposure across platforms and threat intelligence sources to detect leaked or sensitive data early.
- Conduct security awareness training: Educate staff on social engineering threats and data exposure risks to reduce human-factor vulnerabilities.

11. Best Practices for Reducing OSINT Footprint

- Minimise public exposure of sensitive data: Avoid posting direct phone numbers, emails, or internal staff information publicly. Use filtered contact forms and official communication channels instead.
- Regularly audit digital presence: Perform periodic OSINT reviews across websites, social platforms, and third-party databases to identify and remove unnecessary exposed information.
- Update and sanitise website content: Remove outdated employee details, technical stack information, and server/version banners that can be leveraged by attackers for reconnaissance.

- Use domain privacy and redaction services: Enable WHOIS privacy to prevent exposure of administrative and personal details, reducing targeting risks.
- Implement access controls and internal portals: Keep operational files, employee communication details, and internal documents behind secure portals instead of publicly accessible pages.
- Encrypt communication channels: Ensure all data collection points, such as login pages and contact forms, use HTTPS and secure handling to prevent interception and scraping.
- Train staff on social engineering awareness: Employees should know how to avoid accidental information leaks on LinkedIn, social media, or public forums.
- Monitor digital footprint continuously: Use automated OSINT monitoring tools to detect leaked emails, exposed credentials, or shared infrastructure links early

12. Conclusion

This OSINT assessment demonstrates how publicly available information, when aggregated, can expose an organisation to serious security risks. Through tools like SpiderFoot and theHarvester, we identified open ports, outdated service versions, shared infrastructure with malicious IP addresses, and exposed contact details. All of which can be leveraged by attackers during the reconnaissance phase. Although these findings do not indicate an active breach, they highlight areas where proactive security measures are necessary. Reducing public data exposure, regularly updating software, and continuously monitoring digital footprints are essential steps to strengthening cyber resilience and minimising the attack surface.